Broken Admin Session Guard (alogin vs aid) & Unauthenticated AJAX Endpoint

SHOP-009 — Vulnerability Assessment Finding Report

Field	Value
Finding ID	SHOP-009
Product	PHPGurukul Online Shopping Portal
Version	V2.0 package (product page labelled V2.1); SQL dump dated 2025-01-02
Developer	Anuj Kumar / PHPGurukul
Assessment Target	http://localhost:8080/shopping/ (authorized local laboratory; localhost only)
Assessment Date	2026-11-01
Severity	Low
CVSS	4.0 / CVSS:4.0 AV:N/AC:L/PR:N/UI:N/VC:L/VI:N/VA:L
CWE	CWE-287 (Improper Authentication) / CWE-306 (Missing Authentication)
OWASP	A01:2021 / A05:2021
CVE Verification	No matching publicly assigned CVE was identified for this specific finding/version during the research performed. (No matching CVE (potentially novel))
Affected URL	admin/* ; admin/get_subcat.php
Affected Parameter	session; cat_id
Affected Role	Admin / Unauthenticated
Authentication	Varies

Executive Summary

Admin login sets $_SESSION['alogin'] but 23 admin pages guard on $_SESSION['aid'], which the code never assigns — so those pages are unreachable by anyone (availability defect). Separately, get_subcat.php has no authentication guard.

Technical Description

20 admin pages check alogin (work); 23 check the never-set aid and fail closed to logout, on every platform. get_subcat.php (no guard) is reachable unauthenticated but uses intval()+htmlentities(), so it only exposes public subcategory names (low).

Root Cause Analysis

Inconsistent session-key naming across the admin codebase; one unguarded AJAX script.

Preconditions

None.

Proof of Concept — Step-by-Step Reproduction

1. Log in as admin; browse to dashboard.php/add-product.php/registered-users.php -> redirected to logout (unreachable).
2. Unauthenticated POST to admin/get_subcat.php (cat_id=4) -> HTTP 200 returns subcategory options.

HTTP Request

```
GET /shopping/admin/dashboard.php (with valid admin session) -> 302 Location: logout.php
```

HTTP Response (evidence)

```
All 23 aid-guarded admin pages redirect to logout regardless of session; get_subcat.php returns 200 unauthenticated.
```

Proof of Concept & Visual Evidence

This finding is confirmed by source-code review and (where noted) database inspection; see the referenced primary evidence. No screenshot is required for a static/offline finding.

Actual Security Impact

Availability: roughly half the admin panel is non-functional as shipped. Confidentiality: minor (public subcategory data via the unguarded AJAX). Note: tested-only via a documented harness that emulates the intended admin state.

Exploitation Complexity

n/a.

Attack Scenario

The shipped admin panel is partly unusable; the AJAX endpoint leaks only public data.

Remediation

Use one consistent session key and a shared require-guard on every admin script; authenticate get_subcat.php.

Secure Code Example

```
// auth.php: if(empty($_SESSION['alogin'])) { header('Location: index.php'); exit; } // require on every admin page
```

Retesting Procedure

After unifying the key, all admin pages become reachable with a valid session and none without.

References

- CWE-287/306; OWASP A01/A05
- Evidence: installation/setup-log.md (guard mapping); get_subcat test

Final Conclusion

Confirmed (guard mapping + dynamic). Low (availability + minor info).

Authorized local-laboratory assessment. Evidence chain sealed (evidence/shopping-portal/SEAL). Draft for human review — not auto-submitted. Secrets/PII in evidence are lab demo data; redact in externally-shared copies.